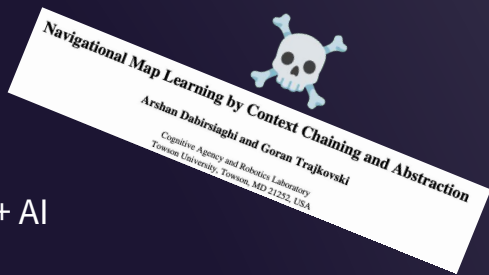


Beyond Detection

What We Learned Testing Every AI Approach to
Vulnerability Classification

Who am I?



2005



M.Sc., Comp. Sci. + AI



Contributor



Security Researcher



Co-Founder, Chief Scientist

2022+



Co-Founder, CTO

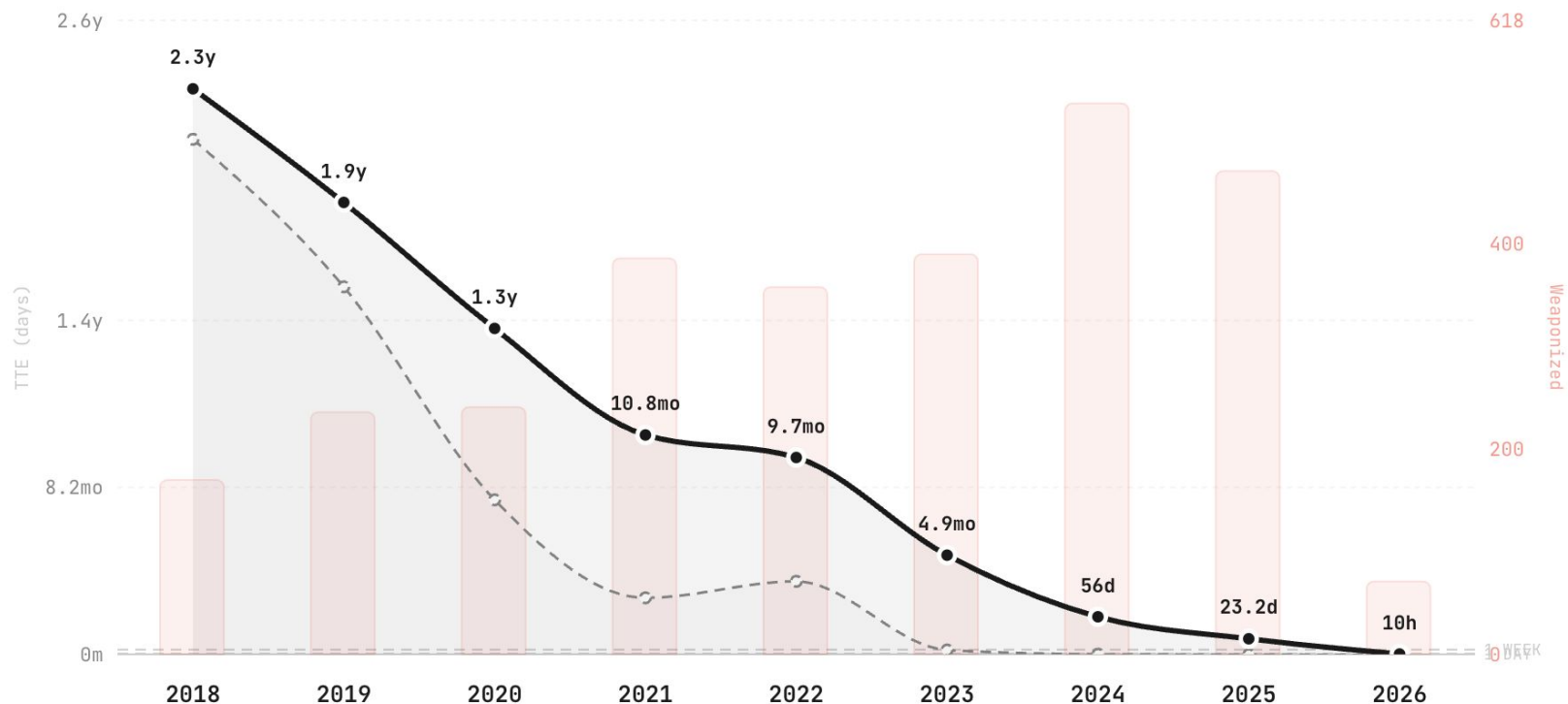
From Vulnerability to Exploitation

TTE (Time-to-Exploit) measures the gap between CVE disclosure and confirmed exploitation

— Mean TTE (10% trimmed, days)

- - - Median TTE (days)

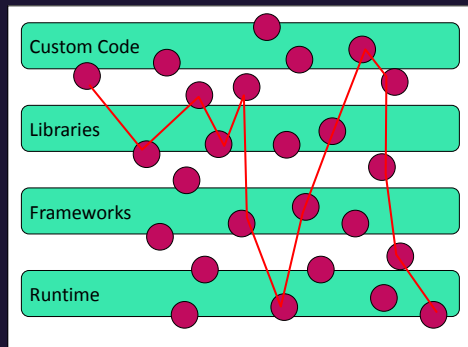
■ Weaponized Exploits (count)



Why do I have this obsession with triaging tool output?



Code Goes Up
Vulns Go Up

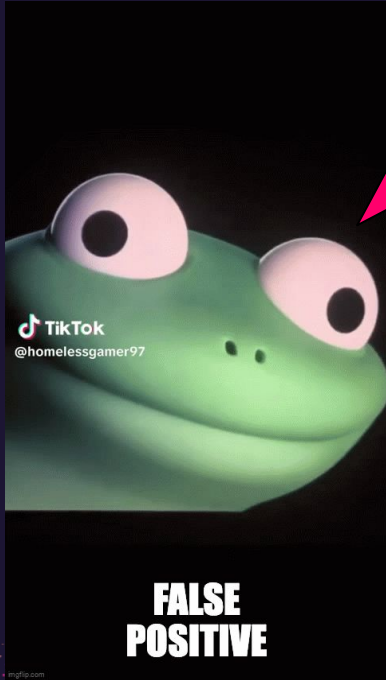


Still Need
Traditional
AST/SCA



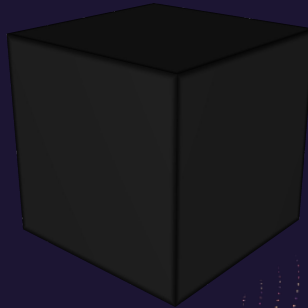
Auto-Fix Without
Triage Harms
Security, Quality,
Performance, *Trust*

What about the reinforcement learning? (It got us this far?)



Reward hacking risks in low signal outcomes

99% accuracy even with 0% sensitivity

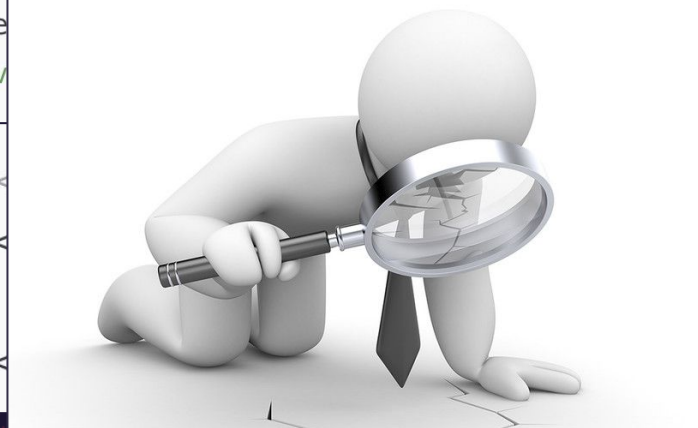


No automated/unsupervised reward model

No explainability, its all lost in the weights

Agentic vulnerability investigation!

```
@Controller
public class ReplyController {
    @PostMapping("/tickets/reply/preview")
    public String preview(@RequestParam("message") String message, Model model) {
        model.addAttribute("reply_preview", message);
        return "reply_preview.html";
    }
}
```



```
/reply_preview.html -->
<div class="reply_preview">{message}</div>
```

"Does this framework escape output by default?"

"Is it a JSON content-type?"

"What is the business context?"

The benchmark

Harnesses

OSS SWE



Claude Code



Structured
Workflows



Decision
Tree

Tools

CodeQL
Snyk
AppScan
Sonar
Semgrep
...

Samples

Data Flow
Non-Data Flow
Common + Not
100+ classes

Synthetic
OSS
Hand-built

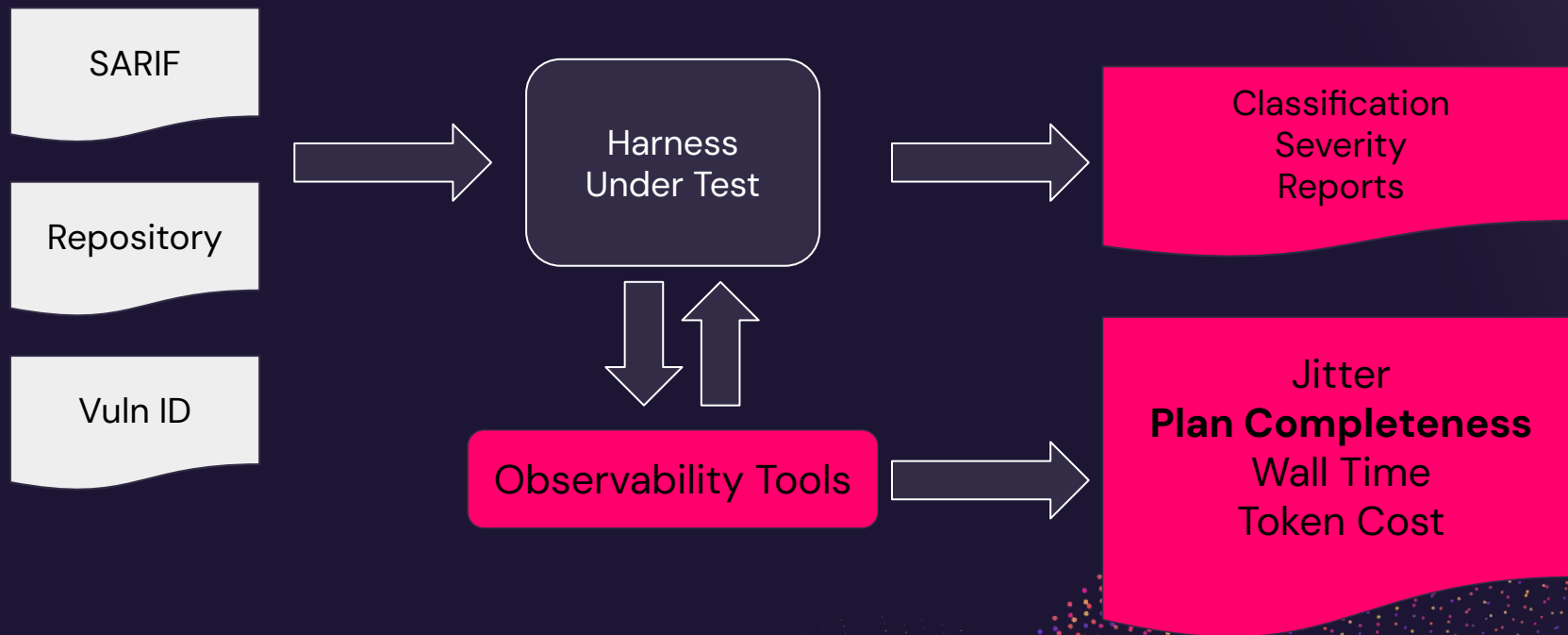
Human-labeled

Metrics

Classification
Accuracy
Severity Accuracy
Jitter
Plan Completeness
Wall Time
Token Cost



The benchmark



Everything is a decision...

What do I do if I can't find a file with that path from the SARIF?

How much surrounding code do I show for each event reported in the vulnerability?

What if the code references a line, and not column info? What if 2 inputs are there?!

How do I detect/handle when the agentic gets distracted by other potentially unsafe behavior?



Investigative Power == Risk



Ability to Research Web
Exfiltration Risk

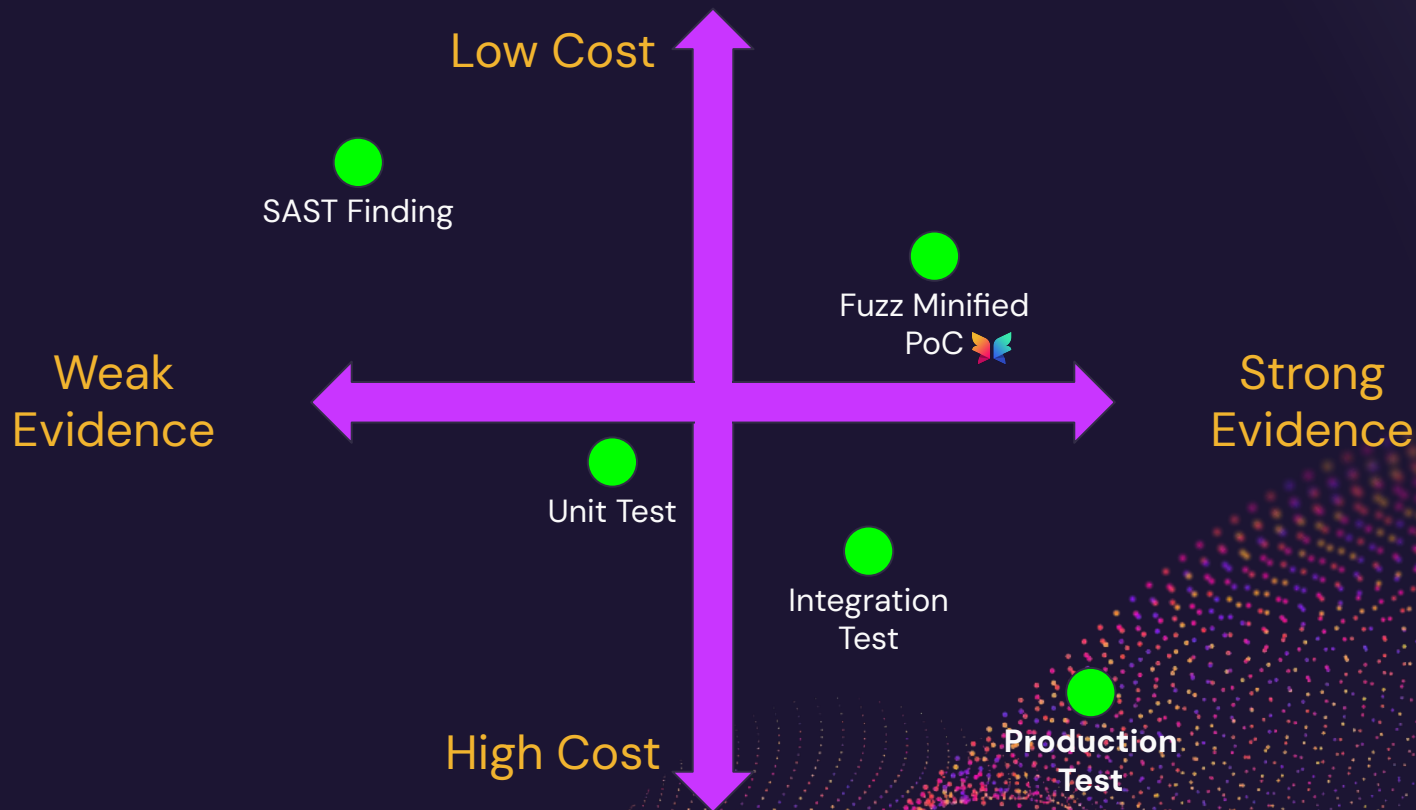


Ability to Write Code / Fuzz
Code Execution Risk



Internal Context Access
Pivot + Exfiltration Risk

Automated verification techniques



Easy stuff is easy!

- ✓ When you don't need a comprehensive plan
- ✓ The obvious factors are the load-bearing factors
- ✓ No context is needed outside of the specifically-highlighted code

```
import static o.a.d.DigestUtils.md5DigestAsHex;

@PostMapping("/login")
public ResponseEntity<String> login(
    @RequestBody LoginRequest request) {
    String username = request.getUsername();
    String password = request.getPassword();
    String md5 = md5DigestAsHex(password.getBytes());
    ...
    return ResponseEntity.ok("Login successful");
}
```

Naive Harness Failure: Temporal Modeling

```
Response.Headers["Location"] =
```

```
"/error.html?err=" + Uri.EscapeDataString(message);
```

INCORRECT

```
function closeThisPage()
```

```
{
```

```
  if ('<%=runat.Text%>'=='1')
```

```
  {
```

```
    var strm = opener.document.all['<%=txt.Text%>'].value;
```

```
    opener.Runat(strm);
```

```
  }
```

```
}
```

INCORRECT

Naive Harness Failure: Schrodinger's Data Flows

```
@RestController
@RequestMapping ("/api/orders")
public class OrderController {
    @GetMapping ("/")
    public Order getOrder(
        @RequestVariable String orderId, HttpServletResponse response) {
        Order order = orderService.getOrder (orderId);
        Writer writer = response.getWriter();
        writer.write("<b>Order Taker: " + order.taker().name() + "</b>");
        writer.write("<b>Order ID: " + orderId + "</b>");
        return order;
    }
}
```

INCORRECT

Naive Harness Failure: Misplaced Tool Trust

```
const credentials = await httpAuth.credentials(req);
const { token } = await auth.getPluginRequestToken({
  onBehalfOf: credentials,
  targetPluginId: 'search',
});
const resultSet = await engine?.query(query, {
  token,
  credentials,
});
```

INCORRECT

Naive Harness Failure: Inconsistent Depth

is this vuln to xss?

```
@PostMapping("/users/update")
@ResponseBody
public String updateUser(@RequestParam String userId,
    @RequestParam String email) {
    // Another state-changing endpoint vulnerable to CSRF
    return "User " + userId + " updated with email: " + email;
}
```

Yes, **potentially**, depending on how the response is rendered.

DAMMIT.

Naive Failure: Plan Completeness



Memory, Context, Context Graphs

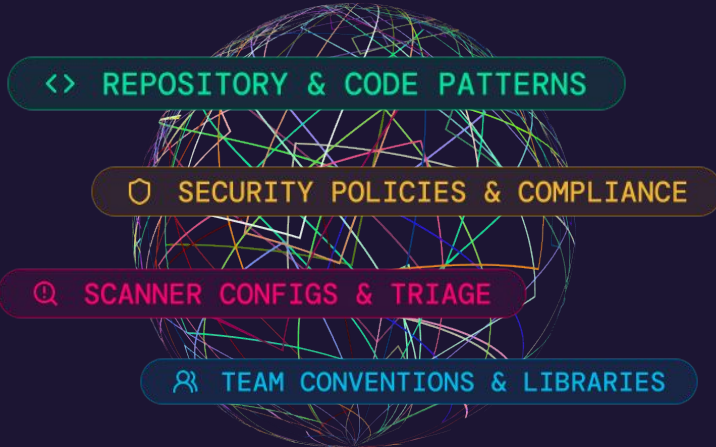
Episodic Memory



Semantic Memory



Procedural Memory



Constant
Knowledge Graph
Re-indexing



Accuracy Up
Agentic Risk Down

Harnesses turn the raw tap into scaled outcomes

- Reasoning failures
- Multi-instruction following
- Stochasticism
- Availability
- Doom loops
- Compounding dera
- Lack of context
- Fencesitting

Judge patterns, knowledge base,
workflows

Workflows

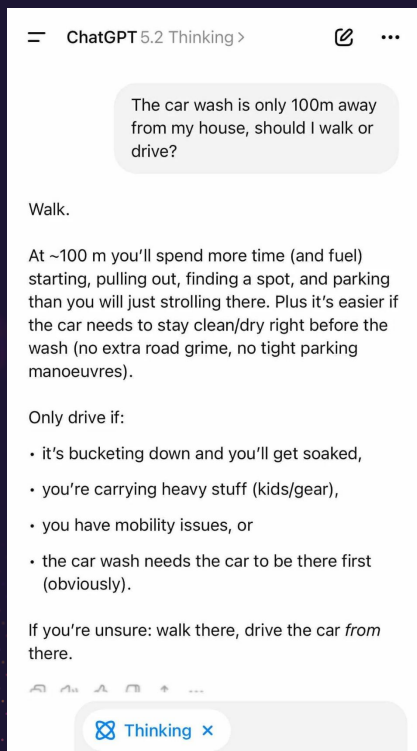
Voting patterns

State management, backpressure,
observability, domain-specific
optimizations

Domain-specific memory +
connections

Prompt engineering

Can we depend on this for security?



Part 1: The Single-Run Test — 42 Out of 53 AI Models Said "Walk"

On a single call, only 11 out of 53 models got it right. 42 said walk.

The models that passed the car wash test:

- Claude Opus 4.6
- Gemini 2.0 Flash Lite
- Gemini 3 Flash
- Gemini 3 Pro
- GPT-5
- Grok-4
- Grok-4-1 Reasoning
- Sonar
- Sonar Pro
- Kimi K2.5
- GLM-5

<https://opper.ai/blog/car-wash-test>

*“Across case studies, agents handled specific, well-scoped requests effectively but could not reliably judge whether their work was scientifically valid or met expectations. **Indeed, agents often expressed confidence even when their work contained clear errors.** Human reviewers therefore needed to find reliable ways to validate the results. The strongest approaches used an external reference or measurable acceptance target such as exact output agreement, parity with an existing tool, appropriate statistical behavior, or answers established in advance using simulated data.”*



Scientific computing in the age of agentic AI

July 28, 2026

<https://openai.com/index/scientific-computing-agentic-ai/>

Where can we depend on this for security?

Assistive **everywhere**.

~95% faster human-in-the-loop reviews with AI-based triage, with low disagreement rates.

Go **fully autonomous** when:

Existing Backlogs

No one was getting to it anyway.

Lower criticality apps

Cost of failure is low.

Past SLA

The deadline already passed.



The cost of a miss can't be infinity

Traditional **defense in depth** is more important than ever.

RASP / ADR / WAF

Can we stop exploitation of an incorrectly classified TP?

Data / Execution Isolation

Can we minimize the blast radius of successfully exploited vulnerabilities?

AI Generated Honeypots

Redirect bad behavior early into death spirals and exhaust tokens.

Behavioral Irregularities

Can we detect anomalous app behavior?



How do you navigate this world?



Thank you!

arshan@pixee.ai



APPENDIX

